

Chapter 26 — Security Architecture

Field	Value
Status	Revised after whole-book constitutional and cross-chapter audit
Version	0.2
Scope	Protect constitutional identity, authority, data, communication, software, and reality-changing actions through layered, evidence-backed controls.
Constitutional basis	Decisions 25, 27, 29, 32, 35–43, 47–50
Owner review	No unresolved Owner decision after whole-book audit

1. Purpose

Protect constitutional identity, authority, data, communication, software, and reality-changing actions through layered, evidence-backed controls.

2. Authoritative Responsibilities

Component	Authoritative responsibility
Security Policy Service	Security rules, risk classes, control requirements, and exception governance
Identity Security Service	Credential lifecycle, step-up authentication, liveness, compromise signals, and revocation
Key and Secrets Service	Key custody, short-lived credentials, rotation, revocation, and audited use
Security Monitor	Threat detection, attack correlation, containment recommendations, and incident evidence
Supply Chain Verifier	Artifact provenance, signatures, dependencies, compatibility, and release evidence

3. Core State and Records

Object	Required content
Security Context	Actor, target, risk, authentication confidence, device/Presence, policy, and environment.
Credential	Subject, scope, issuer, proof type, issue/expiry, revocation, hardware binding, and use constraints.
Threat Observation	Source, indicator, affected assets, confidence, severity, evidence, and recommended containment.
Security Exception	Exact control, reason, scope, duration, compensating controls, authorization, and review.

4. Runtime Workflow

1. Authenticate every actor and component cryptographically; treat local network location as untrusted context.
2. Evaluate least-privilege authority, purpose, device/Presence, risk, and fresh policy for each protected action.
3. Use scoped, short-lived credentials and secret references rather than distributing ambient secrets.
4. Verify signed software provenance and compatibility before loading executable artifacts.
5. Monitor for identity, behavior, integrity, exfiltration, replay, escalation, and supply-chain anomalies.
6. Contain suspected compromise by the narrowest safe boundary and preserve evidence.
7. Recover through verified identity, state, credentials, software, and post-incident validation.

5. Interfaces and Contracts

Commands, queries, events, records, and evidence are typed, versioned, authenticated, authorized, correlated, and classified. Mutation is accepted only by the authoritative owner. Every external or reality-changing boundary carries identity, policy, authority, provenance, integrity, time, and transaction context.

6. Failure and Recovery

- Security dependency unavailable: protected actions fail closed or enter a predefined safe state.
- Credential compromise: revoke the credential and quarantine affected sessions without redefining identity.
- Key loss: recover through separately protected Owner and continuity procedures; never bypass authentication.

- Urgent vulnerability: accelerate verification and rollout but retain authorization and recoverability.

7. Constitutional Guarantees

- Authority is explicit, least-privilege, purpose-bound, time-bounded where possible, and continuously auditable.
- Encryption provides confidentiality and integrity but does not replace identity, authorization, or privacy policy.
- Security failure cannot silently make HAL more permissive or more restrictive.
- HAL protects its constitutional kernel more strongly than replaceable capabilities and providers.

8. Prohibited Behaviors

- No component may silently broaden or narrow constitutional authority, reinterpret Owner intent, erase dissent, or promote derived state to authority.
- No failure, degraded dependency, emergency, or optimization may silently change identity, policy, trust, authentication, evidence, or verification rules.
- No model, service, provider, node, Presence, credential, relationship, environment, or network location receives constitutional authority by implication.

9. Observability and Verification

The subsystem records identity, correlation, authority/policy context, inputs, state versions, decisions, limitations, failures, recovery, and outcomes. Verification is risk-scaled, reproducible, and stored as durable evidence. Status and explanation derive from governed state rather than model assertion.

10. Source Alignment and Review

This chapter implements Decisions 25, 27, 29, 32, 35–43, 47–50. Final source-alignment and constitutional disposition is recorded in the batch audit reports; embedded approval text is not treated as review evidence.

Whole-Book Audit Resolution

The following requirements supersede any ambiguous earlier wording in this chapter and are incorporated into this edition:

- Embedded author approval is not conformance evidence. This chapter's constitutional status is determined only by the independent whole-book audit.
- No substantive constitutional or cross-chapter correction was required in this edition.